Healthcheck analysis

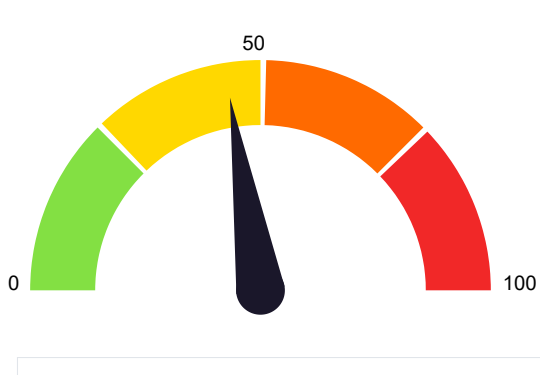
Date: 2026-05-25 - Engine version: 3.5.0.44

This report has been generated with the Basic Edition of PingCastle.
Being part of a commercial package is forbidden (selling the information contained in the report).
If you are an auditor, you MUST purchase an Auditor license to share the development effort.

Active Directory Indicators

This section focuses on the core security indicators.
Locate the sub-process determining the score and fix some rules in that area to get a score improvement.

Indicators

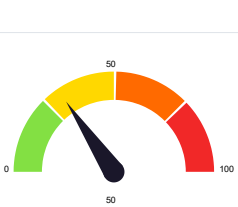


Domain Risk Level: 45 / 100

It is the maximum score of the 4 indicators and one score cannot be higher than 100. The lower the better

Compare with statistics

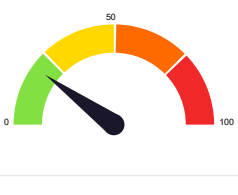
Privacy notice



Stale Object : 31 /100

It is about operations related to user or computer objects

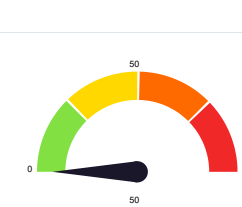
11 rules matched



Privileged Accounts : 20 /100

It is about administrators of the Active Directory

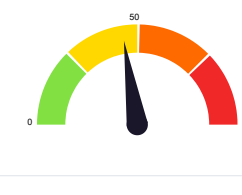
3 rules matched



Trusts : 0 /100

It is about connections between two Active Directories

0 rules matched



Anomalies : 45 /100

It is about specific security control points

12 rules matched

Risk model

Left-click on the headlines in the boxes for more details

Stale Objects	Privileged accounts	Trusts	Anomalies
Inactive user or computer	Account take over	Old trust protocol	🟨 Audit
🟨 Network topography	ACL Check	SID Filtering	🟨 Backup
🟨 Object configuration	Admin control	SIDHistory	Certificate take over
Obsolete OS	Control paths	Trust impermeability	Golden ticket
🟧 Old authentication protocols	Delegation Check	Trust inactive	Local group vulnerability
🟨 Provisioning	🟧 Irreversible change	Trust with Entra	🟨 Network sniffing
Replication	Privilege control		🟧 Pass-the-credential
Vulnerability management	Read-Only Domain Controllers		Password retrieval
			🟦 Reconnaissance
			Temporary admins
			🟨 Weak password

Legend:
☐ score is 0 - no risk identified
🟦 score is 0 - no risk identified but some improvements detected
🟨 score between 1 and 10 - a few actions have been identified
🟧 score between 10 and 30 - rules should be looked with attention
🟥 score higher than 30 - major risks identified

Maturity Level

This section represents the maturity score (inspired from ANSSI).

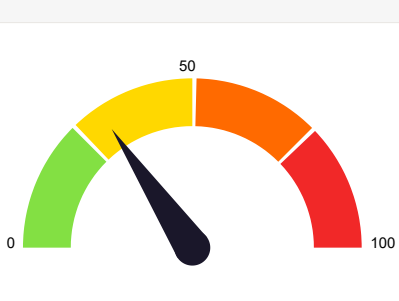
This feature is reserved for customers who have purchased a license

MITRE ATT&CK®

This section represents an evaluation of the techniques available in the MITRE ATT&CK®

This feature is reserved for customers who have purchased a license

Stale Objects



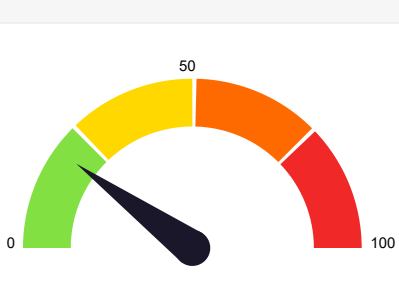
Stale Objects : 31 /100

It is about operations related to user or computer objects

Stale Objects rule details [11 rules matched on a total of 56]

The LAN Manager Authentication Level allows the use of NTLMv1 or LM.	+ 15 Point(s)
Non-admin users can add up to 10 computer(s) to a domain	+ 10 Point(s)
The subnet declaration is incomplete [1 IP of DC not found in declared subnets]	+ 5 Point(s)
Number of accounts which have never expiring passwords: 1	+ 1 Point(s)
Verify Kerberos Armoring is enabled on DCs and the domain functional level is at least Windows Server 2012	Informative rule
Verify Kerberos Armoring is enabled on clients and the domain functional level is at least Windows Server 2012	Informative rule
Some script extensions, used in phishing, can be directly run by double clicking on it	Informative rule
Not all possible Defender ASR mitigations are in Block or Warn mode	Informative rule
Presence of service accounts without AES support = 3	Informative rule
It is possible for scripts engine used by hackers to connect directly to the Internet	Informative rule
The GPO are not pushing recommended configuration for Terminal Services	Informative rule

Privileged Accounts



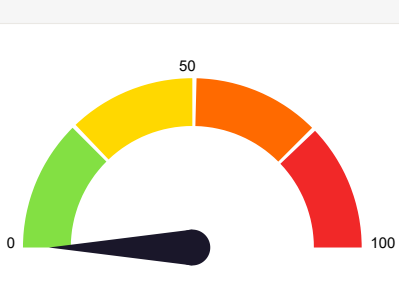
Privileged Accounts : 20 /100

It is about administrators of the Active Directory

Privileged Accounts rule details [3 rules matched on a total of 46]

The group Schema Admins is not empty: 1 account(s)	+ 10 Point(s)
The Recycle Bin is not enabled	+ 10 Point(s)
OU without the accidental deletion protection have been found	Informative rule

Trusts



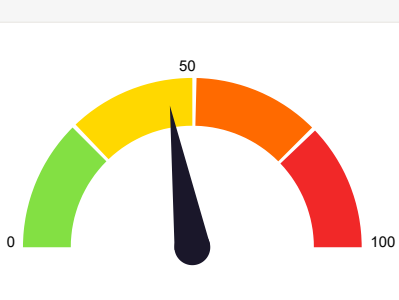
Trusts : 0 /100

It is about links between two Active Directories

Trusts rule details [0 rules matched on a total of 12]

No rule matched

Anomalies analysis



Anomalies : 45 /100

It is about specific security control points

Anomalies rule details [12 rules matched on a total of 73]

LAPS doesn't seem to be installed	+ 15 Point(s)
The audit policy on domain controllers does not collect key events.	+ 10 Point(s)
Policy where the password length is less than 8 characters: 1	+ 10 Point(s)
The number of DCs is too small to provide redundancy: 1 DC	+ 5 Point(s)
Hardened Paths have been modified to lower the security level	+ 5 Point(s)
No GPO has been found which implements NetCease	Informative rule
Authenticated Users can create DNS records	Informative rule
Anonymous Binding to the rootDse is enabled	Informative rule
DsHeuristics has not been set to enable the mitigation for CVE-2021-42291	Informative rule
No password policy for service accounts found (MinimumPasswordLength>=20)	Informative rule
The PreWin2000 compatible group contains "Authenticated Users"	Informative rule
The PowerShell audit configuration is not fully enabled.	Informative rule

Domain Information

This section shows the main technical characteristics of the domain.

Domain	Netbios Name	Domain Functional Level	Forest Functional Level	Creation date	DC count	Schema version	Recycle Bin enabled
sentinel.local	SENTINEL	Windows Server 2016	Windows Server 2016	2026-05-21 00:07:18Z	1	Windows Server 2019	FALSE

Entra ID Configuration

No Entra ID configuration has been found in this domain

User Information

This section gives information about the user accounts stored in the Active Directory

Honey Pot

A honey pot has been configured. It is used to generate fake security issues that are heavily monitored and that a hacker will spot using security tools like PingCastle. By enabling this feature, all the accounts listed below will not be evaluated with PingCastle rules.

Honey pot accounts	[3]

Account analysis

Nb User Accounts	Nb Enabled	Nb Disabled	Nb Active	Nb Inactive	Nb AccessDenied	Nb Locked	Nb pwd never Expire	Nb SidHistory	Nb Bad PrimaryGroup	Nb Password not Req.	Nb Des enabled.
11	8	3	8	0	0	0	1	0	0	0	0

Objects with a password which never expires	[1]
Objects where AES usage with kerberos may be cause issues	[2]

Password Age Distribution

This feature is reserved for customers who have purchased a license

Computer Information

Account analysis

This section gives information about the computer accounts stored in the Active Directory

Nb Computer Accounts	Nb Enabled	Nb Disabled	Nb Active	Nb Inactive	Nb AccessDenied	Nb SidHistory	Nb Bad PrimaryGroup	Nb unconstrained delegations (enabled)	Nb unconstrained delegations (disabled)	Nb Reversible password
2	2	0	2	0	0	0	1	0	0	

Objects where AES usage with kerberos may be cause issues	[1]
Objects trusted to authenticate for delegation for enabled accounts	[1]

Operating Systems

If you need to find the computers running a specific OS, we advise to use PingCastle.exe and the export / computers feature available from the main menu. Indeed the computer details are not included in the report for performance issues. Doing this will impact significantly the report size and the time to load the report.

Operating System	Nb OS	Nb Enabled	Nb Disabled	Nb Active	Nb Inactive	Nb AccessDenied	Nb SidHistory
Windows Server 2022 21H2	1	1	0	1	0	0	0
Windows 11 (Build 26200)	1	1	0	1	0	0	0

Showing 1 to 2 of 2 rows

Domain controllers

Here is a specific zoom related to the Active Directory servers: the domain controllers.

Domain controllers	[1]

LAPS Analysis

This feature is reserved for customers who have purchased a license

Admin Groups

Groups

This section is focused on the groups which are critical for admin activities. If the report has been saved which the full details, each group can be zoomed with its members. If it is not the case, for privacy reasons, only general statistics are available.

Group Name	Nb Admins	Nb Enabled	Nb Disabled	Nb Inactive	Nb PWd never expire	Nb Smart Card required
Account Operators	0	0	0	0	0	0
Administrators	1	1	0	0	1	0
Backup Operators	0	0	0	0	0	0
Certificate Operators	0	0	0	0	0	0
Certificate Publishers	0	0	0	0	0	0
Dns Admins	0	0	0	0	0	0
Domain Administrators	1	1	0	0	1	0
Enterprise Administrators	1	1	0	0	1	0
Enterprise Key Administrators	0	0	0	0	0	0
Key Administrators	0	0	0	0	0	0

Showing 1 to 10 of 14 rows 10 rows per page ‹ 1 2 ›

All users in Admins groups	[1]

Last Logon Distribution

This feature is reserved for customers who have purchased a license

Delegations

Each specific rights defined for Organizational Unit (OU) are listed below.

All delegations	[12]

The OU that are listed as not protected are:

Unprotected OU	[1]

In particular for AD database access (DCSync, AADConnect, ...).

AD Database Access	[1]

Control Paths Analysis

This section focuses on permissions issues that can be exploited to take control of the domain.
This is an advanced section that should be examined after having looked at the Admin Groups section.

Foreign domain involved

This analysis focuses on accounts found in control path and located in other domains.

No operative link with other domains has been found.

Indirect links

This part tries to summarize in a single table if major issues have been found.
Focus on finding critical objects such as the Everyone group then try to decrease the number of objects having indirect access.
The detail is displayed below.

Priority to remediate	Critical Object Found	Number of objects with Indirect	Max number of indirect numbers	Max ratio
Critical	NO	0	0	0
High	NO	0	0	0
Medium	NO	0	0	0
Other	NO	0	0	0

Showing 1 to 4 of 4 rows

Admin groups

If the report has been saved which the full details, each object can be zoomed with its full detail. If it is not the case, for privacy reasons, only general statistics are available.

Group or user account	Priority	Users member	Computer member of the group	Indirect control	Unresolved members
Account Operators	High	0	0	0	0
Administrator	Critical			0	0
Administrators	Critical	1 (Details)	0	0	0
Backup Operators	High	0	0	0	0
Certificate Operators	Medium	0	0	0	0
Certificate Publishers	Other	0	0	0	0
Dns Admins	Medium	0	0	0	0
Domain Administrators	Critical	1 (Details)	0	0	0
Enterprise Administrators	Critical	1 (Details)	0	0	0
Enterprise Key Administrators	Medium	0	0	0	0

Showing 1 to 10 of 15 rows 10 rows per page ‹ 1 2 ›

Critical Infrastructure

If the report has been saved which the full details, each object can be zoomed with its full detail. If it is not the case, for privacy reasons, only general statistics are available.

Group or user account	Priority	Users member	Computer member of the group	Indirect control	Unresolved members
AdminSDHolder container	Critical			0	0
Builtin OU	Medium			0	0
Computers container	Medium			0	0
Domain Controllers	Critical	0	1 (Details)	0	0
Domain Root	Medium			0	0
Enterprise Read Only Domain Controllers	Other	0	0	0	0
Group Policy Creator Owners	Medium	1 (Details)	0	0	0
Krbtgt account	Medium			0	0
Read Only Domain Controllers	Medium	0	0	0	0
Users container	Medium			0	0

Showing 1 to 10 of 10 rows

Trusts details

This section focuses on the relations that this domain has with other domains

Discovered Domains

This part displays the direct links that this domain has with other domains.

Trust Partner	Type	Attribut	Direction	SID Filtering active	TGT Delegation	Creation	Is Active ?	Algorithm
No matching records found								

Reachable Domains

These are the domains that PingCastle was able to detect but which is not releated to direct trusts. It may be children of a forest or bastions.

Reachable domain	Discovered using	Netbios	Creation date
No matching records found			

PKI

Certificates

This detects trusted certificates which can be used in man in the middle attacks, or which can issue smart card logon certificates

Number of trusted certificates: 0

Trusted certificates	[0]

Infrastructure

Microsoft Entra Connect settings

Microsoft Entra Connect help maintaining a synchronization between the Active Directory and Entra ID. Microsoft Entra Connect servers should be considered as Tiers0 as they usually have the right to read the hashes of the user passwords.

Identifier	Computer	Tenant	IsEnabled	Created	LastLogon	PwdLastSet	Computer object found
No matching records found							

WSUS settings

WSUS settings allow workstations and servers located on the intranet to be updated. The reference documentation is here. Here are the settings found in GPO.

Policy Name	WSUS Server	UseWUServer	ElevateNonAdmins	AUOptions	NoAutoUpdate	NoAutoRebootWithLoggedOn
No matching records found						

Exchange settings

Exchange is the mail server of Microsoft. Because it is deeply integrated into the Active Directory, it is a component to be monitored

PingCastle is checking objects of type msExchExchangeServer and the schema to provide the information below.

Name	In service date	Version	Proxy
No matching records found			

SCCM settings

SCCM or its more recent name Microsoft Endpoint Manager is the Microsoft tool to manage the workstations and servers. It is used typically to deploy packages.

PingCastle is checking objects of type mSSMSManagementPoint and the schema to provide the information below.

Name	Version	Client operational version	AAD TenantID	AAD TenantName
No matching records found				

Service Connection Points

Service Connection Points are a configuration stored in the AD to expose services to all computers.

Service	Class	DNS	Binding Info	DN
No matching records found				

Replacement of RC4 by AES in kerberos

This section checks for known pain points in AES activation and RC4 removal for kerberos

This feature is reserved for customers who have purchased a license

Anomalies

This section focuses on security checks specific to the Active Directory environment.

Backup

The program checks the last date of the AD backup. This date is computed using the replication metadata of the attribute dsaSignature (reference).

Last backup date: 2026-05-21 15:41:06Z

LAPS

LAPS is used to have a unique local administrator password on all workstations / servers of the domain. Then this password is changed at a fixed interval. The risk is when a local administrator hash is retrieved and used on other workstation in a pass-the-hash attack. Please note that the LAPS schema is installed on the forest and as a consequence the installation date can be before the domain creation date.

Mitigation: having a process when a new workstation is created or install LAPS and apply it through a GPO

Legacy LAPS installation date: Never

Windows LAPS installation date: Never

Windows Event Forwarding (WEF)

Windows Event Forwarding is a native mechanism used to collect logs on all workstations / servers of the domain. Microsoft recommends to Use Windows Event Forwarding to help with intrusion detection Here is the list of servers configured for WEF found in GPO

Number of WEF configuration found: 0

krbtgt (Used for Golden ticket attacks)

The account password for the *krbtgt* account should be rotated twice yearly at a minimum. More frequent password rotations are recommended, with 40 days the current recommendation by ANSSI. Additional rotations based on external events, such as departure of an employee who had privileged network access, are also strongly recommended.

You can perform this action using this script

You can use the version gathered using replication metadata from two reports to guess the frequency of the password change or if the two consecutive resets have been done. Version starts at 1.

Kerberos password last changed: 2026-05-20 20:09:27Z **version:** 2

AdminSDHolder (detect temporary elevated accounts)

This control detects accounts which are former 'unofficial' admins. Indeed when an account belongs to a privileged group, the attribute admincount is set. If the attribute is set without being an official member, this is suspicious. To suppress this warning, the attribute admincount of these accounts should be removed after review.

Number of accounts to review: 0

Unix Passwords

This control detects if one of the attributes userPassword or unixUserPassword has been set on accounts. Indeed, these attributes are designed to store encrypted secrets for unix (or mainframe) interconnection. However in the large majority, interconnected systems are poorly designed and the user password is stored in these attributes in clear text or poorly encrypted. The userPassword attribute is also used in classic LDAP systems to change the user password by setting its value. But, with Active Directory, it is considered by default as a normal attribute and doesn't trigger a password but shows instead the password in clear text.

Number of accounts to review: 0

Java code reference

This control detects if one of the attributes javaCodebase, javaFactory or javaClassname has been set on accounts. Indeed, these attributes are designed to add custom code to AD object when running java code. However it can be abused to run code on servers having the flag com.sun.jndi.ldap.object.trustURLCodebase set to true. This is a vulnerability similar to the log4shell vulnerability.

Java Schema extension: Not Found

No active user account found with Java code

Logon scripts

You can check here for backdoors or typos in the scriptPath attribute

Script Name	Count
None	8

Showing 1 to 1 of 1 rows

Advanced

This section display advanced information, if any has been found

Password Policies

Password policies

Note: PSO (Password Settings Objects) will be visible only if the user, which collected the information, has the permission to view it.
PSO shown in the report will be prefixed by "PSO:"

Policy Name	Complexity	Max Password Age	Min Password Age	Min Password Length	Password History	Reversible Encryption
Default Domain Policy	True	42 day(s)	1 day(s)	7	24	False
Sentinel-Baseline	True	90 day(s)	30 day(s)	14	24	Not Set

Showing 1 to 2 of 2 rows

Screensaver policies

This is the settings related to screensavers stored in Group Policies. Each non compliant setting is written in red.

Policy Name	Screensaver enforced	Password request	Start after (seconds)	Grace Period (seconds)
No matching records found				

GPO

This section focuses on security settings stored in the Active Directory technical security policies.

Obfuscated Passwords

The password in GPO are obfuscated, not encrypted. Consider any passwords listed here as compromised and change them immediately.

Restricted Groups

Giving local group membership in a GPO is a way to become administrator.
The local admin of a domain controller can become domain administrator instantly.

Security settings

A GPO can be used to deploy security settings to workstations.
The best practice out of the default security baseline is reported in green.
The following settings in red are unusual and may need to be reviewed.
Each setting is accompanied with its value and a link to the GPO explanation.

You will find below the checks where no occurences have been found

Policy Name	Setting	Value
Sentinel-Baseline	Turn off multicast name resolution (Technical details)	LLMNR disabled

Showing 1 to 1 of 1 rows

Audit settings

Audit settings allow the system to generate logs which are useful to detect intrusions. Here are the settings found in GPO.

Simple audit events are described here and Advanced audit events are described here

You can get a list of all audit settings with the command line: `auditpol.exe /get /category:*` (source)

Simple audit settings are located in: Computer Configuration / Policies / Windows Settings / Security Settings / Local Policies / Audit Policy. Simple audit settings are named [Simple Audit].

Advanced audit settings are located in: Computer Configuration / Policies / Windows Settings / Security Settings / Advanced Audit Policy Configuration. This category is displayed below.

Policy Name	Category	Setting	Value
Sentinel-Baseline	[Simple Audit]	Audit system events	Success and Failure
Sentinel-Baseline	[Simple Audit]	Audit logon events	Success and Failure
Sentinel-Baseline	[Simple Audit]	Audit object access	Success and Failure
Sentinel-Baseline	[Simple Audit]	Audit privilege use	Success and Failure
Sentinel-Baseline	[Simple Audit]	Audit policy change	Success and Failure
Sentinel-Baseline	[Simple Audit]	Audit account management	Success and Failure
Sentinel-Baseline	[Simple Audit]	Audit process tracking	Success and Failure
Sentinel-Baseline	[Simple Audit]	Audit directory service access	Success and Failure
Sentinel-Baseline	[Simple Audit]	Audit account logon events	Success and Failure

Showing 1 to 9 of 9 rows

Privileges

Giving privileges in a GPO is a way to become administrator without being part of a group.
For example, SeTcbPriviledge gives the right to act as SYSTEM, which has more privileges than the administrator account.

GPO Name	Privilege	Members
Default Domain Controllers Policy	SeAssignPrimaryTokenPrivilege	NT AUTHORITY\NETWORK SERVICE
Default Domain Controllers Policy	SeAssignPrimaryTokenPrivilege	NT AUTHORITY\LOCAL SERVICE
Default Domain Controllers Policy	SeBackupPrivilege	BUILTIN\Server Operators
Default Domain Controllers Policy	SeBackupPrivilege	BUILTIN\Backup Operators
Default Domain Controllers Policy	SeBackupPrivilege	Administrators
Default Domain Controllers Policy	SeDebugPrivilege	Administrators
Default Domain Controllers Policy	SeLoadDriverPrivilege	BUILTIN\Print Operators
Default Domain Controllers Policy	SeLoadDriverPrivilege	Administrators
Default Domain Controllers Policy	SeMachineAccountPrivilege	Authenticated Users
Default Domain Controllers Policy	SeRestorePrivilege	BUILTIN\Server Operators

Showing 1 to 10 of 15 rows 10 rows per page ‹ 1 2 ›

Login

Login authorization and restriction can be set by GPOs. Indeed, by default, everyone is allowed to login on every computer except domain controllers. Defining login restriction is a way to have different isolated tiers. Here are the settings found in GPOs.

GPO Name	Privilege	Members
Default Domain Controllers Policy	Log on as a batch job	BUILTIN\Performance Log Users
Default Domain Controllers Policy	Log on as a batch job	BUILTIN\Backup Operators
Default Domain Controllers Policy	Log on as a batch job	Administrators
Default Domain Controllers Policy	Allow log on locally	NT AUTHORITY\ENTERPRISE DOMAIN CONTROLLERS
Default Domain Controllers Policy	Allow log on locally	BUILTIN\Print Operators
Default Domain Controllers Policy	Allow log on locally	BUILTIN\Server Operators
Default Domain Controllers Policy	Allow log on locally	BUILTIN\Account Operators
Default Domain Controllers Policy	Allow log on locally	BUILTIN\Backup Operators
Default Domain Controllers Policy	Allow log on locally	Administrators
Default Domain Controllers Policy	Access this computer from the network	BUILTIN\Pre-Windows 2000 Compatible Access

Showing 1 to 10 of 14 rows 10 rows per page ‹ 1 2 ›

GPO Login script

A GPO login script is a way to force the execution of data on behalf of users. Only enabled users are analyzed.

GPO Deployed Files

A GPO can be used to deploy applications or copy files. These files may be controlled by a third party to control the execution of local programs.

Folder Options

File associations may be managed through Group Policy Objects (GPO) by navigating to "Folder Options". This setting is located under Computer Configuration / Preferences / Control Panel Settings / Folders Options in the GPO.

This method serves as an effective countermeasure against script execution from phishing emails by setting Notepad as the default program for opening script files, rather than the script engine. The script extensions that can be reconfigured include: .js, .jse, .vbs, .vbe, .vb, .wsh, and .wsf. Specifically, JavaScript files with extensions .js and .jse can be safely altered to open with Notepad. Other file extensions may have an impact and needs to be assessed before being configured.

GPO Name	Type	Action	Application
No matching records found			

Microsoft Defender ASR (attack surface reduction)

Microsoft Defender is the default Antivirus shipped with Windows. There are many alternatives, but if a computer is installed without an antivirus, it will be enabled by default.

A set of mitigation named ASR (attack surface reduction) can be enabled, even on non premium version of Microsoft Defender Antivirus (formerly Windows Defender Antivirus). Some protections are available since Windows 10 1710 and even Windows 2012 R2. See https://learn.microsoft.com/en-us/defender-endpoint/attack-surface-reduction-rules-reference?view=o365-worldwide for more information.

To enable a mitigation, enable the GPO "Configure Attack Surface Reduction rules" in Computer Configuration / Policies / Administrative Templates / Windows Components / Microsoft Defender Antivirus (formerly Windows Defender Antivirus) / Microsoft (Windows) Defender Exploit Guard / Attack Surface Reduction. After having Enabled the setting, click on Set the state for each ASR rule. Add the GUID of the mitigation as Value name and set 1 as Value to enforce the Block mode. Example for Block JavaScript or VBScript from launching downloaded executable content: d3e037e1-3eb8-44c8-a917-57927947596d. The other values are: 2 for Audit and 6 for Warn.

GPO Name	Rule	Description	Action
No matching records found			

Firewall configuration

Firewall rules may be managed through Group Policy Objects (GPO). This setting is located under Computer Configuration / Policies Windows Settings / Security Settings / Windows Defender Firewall with Advanced Security.

GPO Name	Name	Active	Direction	Action	Application	Remote IP
No matching records found						